IEG 312 – Distributed System Security

Dr. Jobin Jose
Assistant Professor
Department of CSE - Cyber Security
Indian Institute of Information Technology, Kottayam

Module 3

- Infrastructure-Level Solutions- Network-Level Solutions, Grid-Level Solutions, Storage-Level Solutions.
- Application-Level Solutions- Application-Level Security Solutions.
- Service-Level Solutions- Services Security Policy, SOA Security Standards Stack, Deployment Architectures for SOA Security.

Service Level Solutions : Service Security Policy

- The main goal of a corporate security policy:
  - protect data by defining procedures, guidelines and practices for configuring and managing security in the corporate environment.
- It is imperative that the policy defines the organization's philosophy and requirements for securing information assets.
- The information security policy now needs additional considerations, for securing assets that are exposed as services.
- The security policy should define the minimum security criteria that are required around a service.
- The policies around service security will typically be an extension of the existing information security policy.
- The security policy is not limited to just network requirements but might additionally define rules and guidelines for the design and development of secure Web services.

Service Level Solutions : Service Security Policy

- **Threat Classification**
  - The initial step to creating an effective information security policy:
  - - evaluating information assets and identifying threats to those assets.
  - Classification of information assets needs to happen based on quantitative (monetary value) and qualitative (intrinsic values) factors.
  - Determining both the monetary value and the intrinsic value of an asset is essential to accurately gauge its worth.
  - To calculate an asset's monetary value, an organization should consider the impact of that asset's data, networks, or systems being compromised in any way.
  - To calculate intrinsic value, the organization should consider a security incident's impact on credibility, reputation, and relationships with key stakeholders.

Service Level Solutions : Service Security Policy

- **Threat Classification**
  - When assessing potential threats, both external and internal threats must be considered.
  - Threat classification additionally defines guidelines that classify a service depending upon various parameters, such as:
    1) Classification of information managed by that service.
    2) Internet or intranet deployments.
    3) Underlying host-system classification to the business.
    4) Qualitative and quantitative risk assessment.
    5) Risk probability and assessment matrix.

Service Level Solutions : Service Security Policy

- **Threat Classification**
  - Examples of the data required for defining a policy around services security are listed below:

    (1) Transport-level security requirements around SSL or secure virtual private networks.

    (2) Allowed service-communication protocols between the consumer and provider; that is, HTTP, SMTP, SOAP, JMS and so on.

    (3) Service proxy or virtualization requirements.

    (4) Port numbers to be exposed for the firewall; JMS/MQ could have additional requirements.

    (5) Network-address translation or IP hiding requirements.

    (6) Authentication requirements like public-key infrastructure (PKI), Kerberos tokens, and unames/pswds.

    (7) Single sign-on (SSO) and identity-management requirements.

    (8) Authorization requirements like security assertions markup language (SAML) or custom authorization schemes.

    (9) Access control requirements to the underlying systems.

    (10) Message-level security and validation requirements.

    (11) Trusted domains and trusted issuing and requesting authorities.

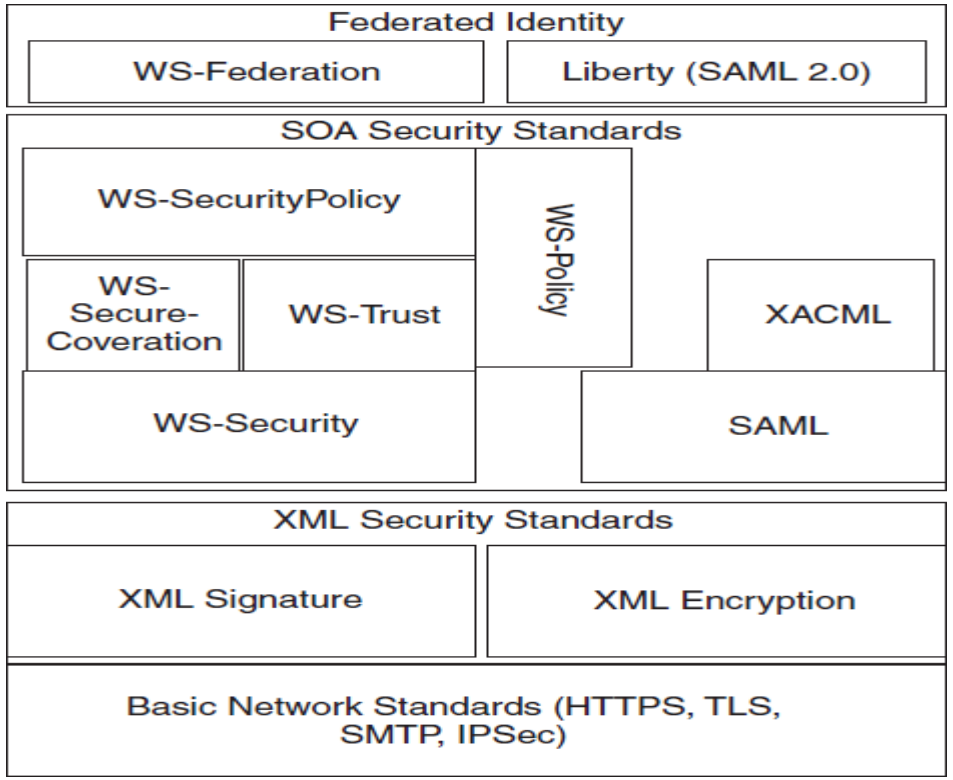
    (12) Other nonfunctional requirements around scalability, availability and so on.

Service Level Solutions : Service Security Policy

- **Threat Classification**
  - Security is often considered a dead investment and hence is often shortchanged.
  - However, we have also come across scenarios where enterprises have become mistrustful and invested a lot of money in security for information which is available in the public domain.
  - Hence the next step is to perform an assessment by weighing security against exposure and the underlying risk.
  - This assessment allows an organization to decide the level of security required for the information.
  - The goal for this risk assessment is to find the optimal line between security costs and risk.
  - This assessment will help in determining the proper allocation of resources once the security policy is effectively in place.

Service Level Solutions : SOA Security Standards Stack

- The standards for security in Web services extend standard mechanisms like encryption, digital signature, and public-key infrastructure to handle XML.
- Some of the protocols are works in progress and some have been standardized already.
- While some of the standards are quite generic and applicable in generic distributed systems involving XML payloads, specialized standards are only suited for Web services applications.



Service Level Solutions : Service Security Policy

- **Inadequacy of SSL for Web Services**
  - One of the key factors in the success of the Web as a platform for e-business and e-commerce has been the availability of scalable security algorithms like SSL.
  - SSL has been a key driver in the adoption of the Web by enterprises for exposing their functionality.
  - SSL refers to a session-layer protocol in computer networking, whereby a series of exchanges of digital keys happens between a client and a server, ending in a secure channel of communication between the two ends, where messages are sent in encrypted form.
  - SSL-based communication can be of two types:
    - Server-side SSL requires that the client obtains a copy of the Web server's certificate so that they can authenticate the server.
    - An encrypted channel for data communication is then established between the client and the server. Hence this provides a one-way authentication.

Service Level Solutions : Service Security Policy

- **Inadequacy of SSL for Web Services**
  - On the other hand, client-side SSL requires both the client and the server to be authenticated,thereby enabling two-way authentication.
  - Hence both service providers and service requesters can be authenticated by using client-side SSL.
  - It might be argued that this is a possible solution for Web services too. This is not so, for the following reasons:

    (1) Web services depend upon the ability of message-processing intermediaries to forward messages, because of the involvement of multi-hop data transfers, while SSL provides for point- to-point security between two points.

    On account of this, if we use SSL, the intermediaries will be the weak points where the security breaks down.

Service Level Solutions : Service Security Policy

- **Inadequacy of SSL for Web Services**

  (2) Client-side SSL, requires the client digital certificates to be as available as the server digital certificates.

  The task of distributing client-side SSL certificates to all possible requesters of a Web service is next to impossible.

  (3) In a Web application, it is usually not necessary to record a transaction as a nonrepudiation proof, but it is important to do so in critical Web services.

  In this context, an SSL session has no memory of an earlier SSL session and hence fails in providing nonrepudiation.

  Imagine a Web service that requires only a one-time execution of a Web service from a client, denying the possibility of a replay attack. This requirement could not be detected with SSL.

  (4) Secure sessions between more than two parties are not addressed by SSL.

Service Level Solutions : Standards in Depth

- Standards are crucial to understanding SOA security. We shall therefore explore here the key security standards.
- **XML Signature**
  - In Web services it is necessary to partially encrypt the body or parts of a Simple Object Access Protocol (SOAP) request, in order to enable transmission with authenticity and integrity assured.
  - Because of the involvement of such multihop data transfers in Web services, the original concept of digital signatures will not extend to XML-based content, as this is based on the idea of getting signatures from the message digests of the entire document.
  - Hence intermediaries need mechanisms for the development of complete trust in the handling of the content of messages keeping partial content intact.
  - Such mechanisms have been provided in the XML Signature specification.
  - XML Signature defines :

    an XML-compliant syntax for representing signatures over Web resources and portions of protocol messages, and procedures for computing and verifying such signatures.

Service Level Solutions : Standards in Depth

- **XML Signature**
  - These will be able to provide data integrity, authentication and/or nonrepudiation.
  - In real-life scenarios it is necessary that in the transmission route of an XML message, different parties sign different parts.
  - XML Signature specification allows for this kind of signing.
  - XML Signature validation requires that the data object that was signed be accessible.
  - The XML Signature itself will generally indicate the location of the original signed object.
  - This can be referenced by a URI within the XML Signature; it can reside within the same resource as the XML Signature(the signature is a sibling), be embedded within the signature (the signature is the parent – enveloping form) or have the signature embedded within itself (the signature is the child – enveloped form).

Service Level Solutions : Standards in Depth

- **XML Signature**
  - Typical computation of the XML Signature of an XML document involves computing the message digest of the document.
  - However, it is necessary to understand that there are many cases where seemingly dissimilar XML documents and nodes actually refer to the same document/node.
  - The idea in canonical XML is to obtain the core of an XML structure so that any two structurally equivalent XML documents are identical byte for byte in their core form.
  - This core form is termed the canonical form of an XML document.
  - Canonicalization refers essentially to the process of conversion of any XML document to its canonical form and is necessary for XML Signature computation.
  - This example uses the DSA with SHA1 algorithm to compute the signature; the XML Signature provides the key values used to compute it.

```
<Signature Id="SriSignature"
      xmlns="http://www.w3.org/2000/09/xmldsig#">
  <SignedInfo >
 <CanonicalizationMethod Algorithm="http://www.w3.org/TR/2001/
       REC-xml-c14n-20010315"/>
 <SignatureMethod Algorithm="http://www.w3.org/2000/09/
       xmldsig#dsa-sha1"/>
   <Reference URI="http://www.w3.org/TR/2000/REC-xhtml1-
         20000126/">
    <Transforms>
     <Transform Algorithm="http://www.w3.org/TR/2001/REC-xml-
           c14n-20010315"/>
   </Transforms>
   <DigestMethod Algorithm="http://www.w3.org/2000/09/
          xmldsig#sha1"/>
    <DigestValue>j71d2Tr3rvEPO0vKtMup4NbeVu8nk=</DigestValue>
   </Reference>
  </SignedInfo>
     <SignatureValue>d12hdlsd7dssf2@4</SignatureValue>
     <KeyInfo>
      <KeyValue>
      <DSAKeyValue>
       <p>33</p><Q>3434</Q><G>3434</G><Y>2323</Y>
      </DSAKeyValue>
      </KeyValue>
     </KeyInfo>
</Signature>
```

Service Level Solutions : Standards in Depth

- **XML Encryption**
  - XML Encryption provides end-to-end security for applications that require a secure exchange of data.
  - XML-based encryption is the natural way to handle complex requirements for security in data-interchange applications.
  - SSL, as we have already shown, cannot handle encryption of partial messages being exchanged, or secure sessions between more than two parties.
  - XML Encryption is built on top of mature cryptographic technology – in this case, shared key encryption technology.
  - Core requirements for XML Encryption are that it must be able to encrypt an arbitrarily-sized XML message and it must do so efficiently.
  - Those two factors led its creators to choose shared-key (symmetric) encryption as the foundation for XML Encryption.
  - Encryption provides for message confidentiality (the message will be secret from all but the intended recipient).

Service Level Solutions : Standards in Depth

- **XML Encryption**
  - The reason XML Encryption is needed over and above transport-level encryption such as SSL is that you need to maintain the confidentiality of a message in the face of the message taking multiple hops on its way to its destination.
  - This will be common when shared services are utilized. You also need confidentiality when the XML message is stored, even after it reaches its final destination.
  - This requirement is called persistent confidentiality.
  - With XML Encryption, each party can maintain secure and insecure states with any of the communicating parties.
  - Use of XML Encryption can be broadly divided into three parts:

    (1) Encrypting the complete XML document.

    (2) Encrypting the XML element.

    (3) Encrypting the content of the XML element.

Service Level Solutions : Standards in Depth

- **XML Encryption**
  - XML Encryption can handle both XML and nonXML (e.g. binary) data. That means we can also send a JPEG file using XML Encryption.
  - Some real-life scenarios where XML Encryption can be applied are:
    - Information exchange between two enterprises. One is an online bookseller and the other is a publisher.
    - The two enterprises exchange information in the form of XML documents. Since some portions of the documents need to be secure and the rest can be sent insecurely, XML Encryption is the natural approach for applying security in this case.
    - We have a secure chat application that has multiple chat rooms with several people each one. XML- encrypted files can be exchanged between chatting parties in such a way that data intended for one particular room will not be easily available to the others.

Service Level Solutions : Standards in Depth

- **XML Encryption**
  - Some real-life scenarios where XML Encryption can be applied are:
    - we need to send an XML file to a publishing company. The file contains details of a book that we need to purchase. It should also contain details about the credit card for the payment. Obviously, we would like to secure this sensitive data.
    - One option is to use SSL, which secures the whole communication. The alternative is to use XML Encryption. If the application requires that the whole communication be secure, we will use SSL. On the other hand, XML Encryption is the best choice if the application requires a combination of secure and insecure communication (which means that some of the data will be securely exchanged and the rest will be exchanged as it is).

Service Level Solutions : Standards in Depth

Web-Services Security (WS-Security)

- Basic standard for message-level security, based on the notion of transmitting relevant tokens as part of SOAP message headers.
- the key requirements of SOA security:
  - loose coupling and interoperability
  - Loose coupling is enabled by separating the information about security from the actual body content
- The salient features of WS-Security are:

(1) It protects the integrity and confidentiality of a Web-services message.

(2) It provides a mechanism for associating security-related claims with the message.

(3) It improves interoperability, as it resolves some of the ambiguities found in SAML, XML encryption and XML Signature by standardizing practices.

(4) It provides support for multiple security tokens, multiple trust domains, multiple signature formats and multiple encryption technologies.

(5) WSS 2004 can support both SOAP 1.1 and SOAP 1.2 – it is defined for a generic SOAP specification and is not tied up with any SOAP versions.

(6) It involves concepts of security tokens.

(7) It can leverage existing security mechanisms like username/password, Kerberos,X.509 certificates

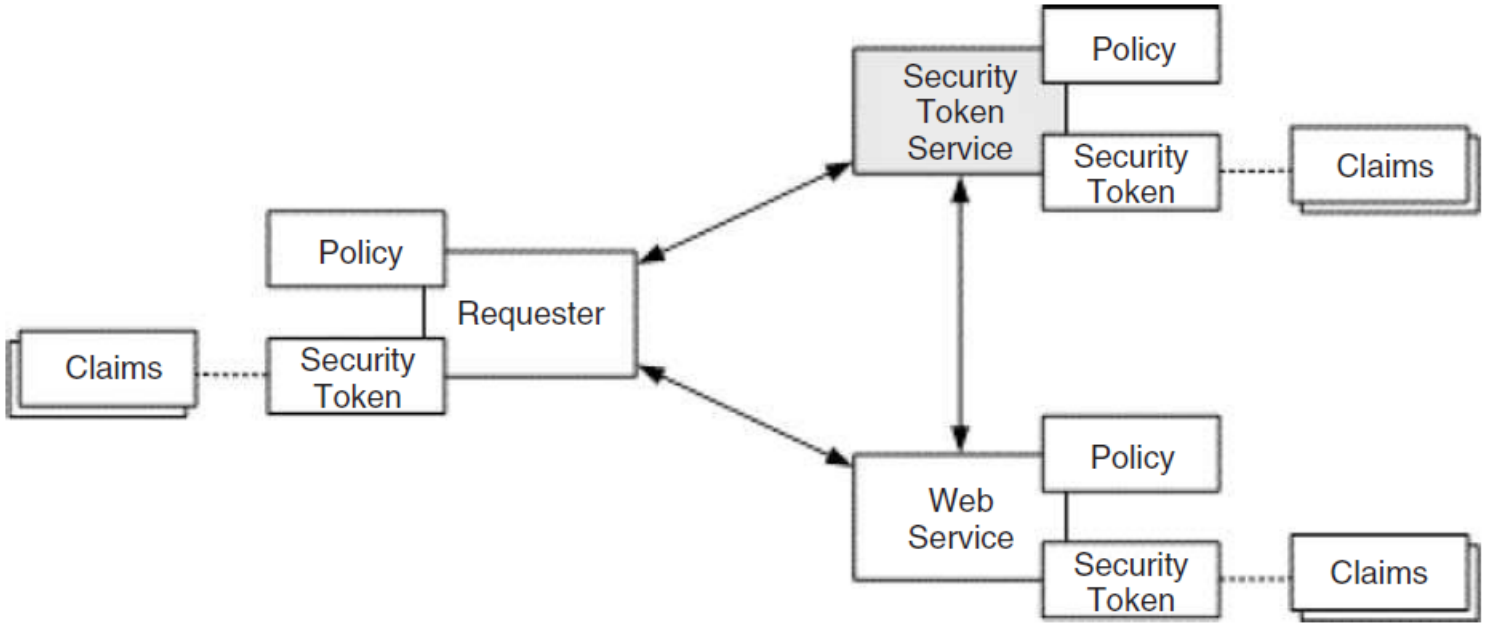
(8) It uses the header in SOAP to store the information.

Service Level Solutions : Standards in Depth

Web-Services Security (WS-Security)

- Web-services security model
- (1)A Web service can require that an incoming message proves a set of claims (e.g. name, key, permission, capability, etc.). If a message arrives without the required claims, the service may ignore or reject it. We refer to the set of required claims and related information as 'policy'.
- (2) A requester can send messages with proof of the required claims by associating security tokens with them. Thus, the messages both demand a specific action and prove that their sender has the claim to demand the action.
- (3) When a requester does not have the required claims, they or someone on their behalf can try to obtain the necessary claims by contacting other Web services. These other Web services, which refers as security token services(STSs), may in turn require their own set of claims. STSs broker trust between different trust domains by issuing security tokens

Web service Security model



Tokens in WS-Security

Username Token element

- Used when a password is already shared between client and server.
- Typically at the client, the digest of the password is attached to the SOAP message.
- This digest contains a hash that is a combination of the password,a nonce (functionally a unique string that identifies a request) and the creation time.
- At the server, the password hash is created again and compared.
- Use of timestamp and saving of nonce can avoid replay attacks

Binary Security Token element

- Provides a means of including X.509 certificates and Kerberos tickets in SOAP security headers.
- Authentication is achieved by attaching the public version of a client's certificate to the SOAP message.
- The message is signed to prove that it has not been tampered with.
- The signature is generated using the private key.
- At server, the signature is verified by getting the decrypted hash back using the client's public key and comparing it with the hash of data sent with the message.
- Encryption can be used for privacy of data. The public key of the receiver is used for encryption and the private key of the receiver for decryption.

Security Token Reference element

- Refers to a means of providing a set of claims that reside at a specific location.
- Security claims indicate a specific right, privilege or attribute.
- Security tokens assert claims that can be attached or referenced.
- One of the main drawbacks associated with WS-Security is its use of asymmetric cryptographic algorithms for encryption, which are computationally intensive

```
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/
    soap/envelope/"
xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:xsi=
    "http://www.w3.org/2001/XMLSchema-instance">
 <soapenv:Header> <wsse:Security soapenv:mustUnderstand="0"
      xmlns:wsse="http://docs.oasis-open.org/wss/2004/01/
      oasis-200401-wss-wssecurity-secext-1.0.xsd">
 <wsse:UsernameToken xmlns:wsse="http://docs.oasis-
      open.org/wss/2004/01/oasis-200401-wss-wssecurity-
      secext-1.0.xsd">
 <wsse:Username xmlns:wsse="http://docs.oasis-
      open.org/wss/2004/01/oasis-200401-wss-wssecurity-
      secext-1.0.xsd">sri</wsse:Username>
 <wsse:Password Type="http://docs.oasis-
      open.org/wss/2004/01/oasis-200401-wss-username-
      token-profile-1.0#PasswordText" xmlns:wsse=
      "http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-
      wssecurity-secext-1.0.xsd">senthil</wsse:Password>
 </wsse:UsernameToken></wsse:Security> </soapenv:Header>
      <soapenv:Body/></soapenv:Envelope>
```

Security Assertions Mark-Up Language (SAML)

- XML-based framework proposed for exchanging authentication and authorization information among disparate Web-access management and security products.
- Security information can be expressed as an XML document and securely transmitted from one application to another.
- The primary goal of SAML is to provide standardized interoperability between security systems that provide authentication and authorization services
- consists of four primary elements:
  - (1) Security assertions.
  - (2) Request/response protocol for generating and returning assertions.
  - (3)Bindings to particular transport protocols (such as SOAP over HTTP).
  - (4) Profiles for how SAML assertions can be embedded or transported between communicating systems.
- An assertion is a declaration of one or more facts (statements) about a subject(eg:user)
- Three types of SAML assertion statement related to security:
  - (1) *Authentication statement:* generated in response to an authentication request.
  - (2) *Attribute statement:* asserts some information about a particular identity.
  - (3) *Authorization decision statement:*

All three statement types have corresponding assertion-request message protocols.
Eg:
(1) Authentication-query request and response.
(2) Attribute-query request and response.
(3) Authorization-decision query request and response.

```
<Assertion xmlns="urn:oasis:names:tc:SAML:1.0:assertion"
    AssertionID="2a23f66c-77fb-4e5c-b276-88c8cee06486"
IssueInstant="2003-05-21T11:25:09Z" Issuer="John Doe"
    MajorVersion="1" MinorVersion="0">
<Conditions NotBefore="2003-05-21T11:25:03Z" NotOnOrAfter=
    "2003-05-21T11:28:03Z"></Conditions>
<AuthenticationStatement AuthenticationInstant=
    "2003-05-21T11:25:03Z"
AuthenticationMethod="urn:oasis:names:tc:SAML:1.0:am:
    unspecified">
<Subject><NameIdentifier>johndoe@aol.com</NameIdentifier>
<SubjectConfirmation>
<ConfirmationMethod>urn:oasis:names:tc:SAML:1.0:cm:bearer
    </ConfirmationMethod>
</SubjectConfirmation>
</Subject>
</AuthenticationStatement>
<AttributeStatement xmlns:xsd="http://www.w3.org/2001/
    XMLSchema" xmlns:xsi="http://www.w3.org/2001/XMLSchema-
    instance">
<Subject><NameIdentifier>johndoe@aol.com</NameIdentifier>
    </Subject>
<Attribute AttributeName="name" AttributeNamespace=
    "namespace">
<AttributeValue>Red</AttributeValue>
</Attribute>
</AttributeStatement>
</Assertion>
```

WS Policy

- Proposed as a standard to capture generic policy requirements for Web services, to work in conjunction with WS-Security.
- It:
  (1)Provides a flexible and extensible grammar for expressing the capabilities,requirements and general characteristics of entities in an XML Web services-based system.
  (2) Defines a framework and a model for the expression of these properties as policies.
  (3) Defines a policy to be a collection of policy alternatives, where each policy alternative is a collection of policy assertions.
  (4)Provides a single policy grammar to allow both kinds of assertion to be reasoned about in a consistent manner.
  (5) Does not specify how policies are discovered or attached to a Web service.

WS-Trust(Trust standard)

- WS-Trust uses the WS-Security base mechanisms and defines additional primitives and extensions for security token exchange to enable the issuance and dissemination of credentials within different trust domains.
- Each entity must exchange security credentials in order to establish secure communication
- Some salient features of WS-Trust as an extension to WS-Security are:

(1) A definition of a means of brokering security credentials among partners within different trust domains.
(2) Methods for issuing, renewing and validating security tokens.
(3) Ways to establish, assess the presence of and broker trust relationships.
(4) A flexible set of mechanisms that can be used to support a range of security protocols.

- The exchange and brokering of security tokens
- Centre of WS-security ->STS(Security Token)The goal of WS-Trust is to enable applications to construct trusted message exchanges.
- Trust is represented through Service'
- This is the intermediate broker that issues the security tokens for all incoming requests

```
<wsr:RequestSecurityTokenResponse>
<wsr:TokenType>
http://schemas.xmlsoap.org/ws/2004/04/security/sc/sct
    </wsr:TokenType>
<wsr:RequestedSecurityToken>
<p:MySecurityToken xmlns:p='http://example.org/mytoken' >
 <!-- Token data -->
 </p:MySecurityToken>
 </wsr:RequestedSecurityToken>
 <ws:AppliesTo>
  <ws:EndpointReference>
      <ws:Address>http://security.org/Webservice/ </ws:Address>
  </ws:EndpointReference>
 </ws:AppliesTo>
 <wsr:Entropy>
 <wsr:BinarySecret>XYZ</wsr:BinarySecret>
 </wsr:Entropy>
  <wsl:Lifetime>
 <wsu:Created>2008-05-06T22:04:34</wsu:Created>
 <wsu:Expires>2008-05-08T10:04:34</wsu:Expires>
  </wsl:Lifetime>

 </wsr:RequestSecurityTokenResponse>
```

WS-Security Policy

- Defines a set of assertions for use with the WS Policy framework with respect to security features provided in WSS:SOAP message security,WS-Trust and WS-Secure Conversation.
- Flexibility with respect to token types, cryptographic algorithms and mechanisms used, including using transport-level security, is part of the design and allows for evolution over time.
- The intent is to provide enough information for compatibility and interoperability.
- To be determined by Web-service participants, along with the information necessary to actually enable a participant to engage in a secure exchange of messages.
- WS Policy defines a framework for allowing Web services to express their constraints and requirements

WS Secure Conversation

- Defines extensions to WS-Security and builds on WS-Trust to govern secure communication across multiple message exchanges.
- Defines a mechanism for sharing security contexts and deriving session keys to tie messages together as a part of a ‘conversation.
- The security context is defined as a new WS-Security token type that is obtained using a binding of WS-Trust.
- The mechanisms defined in WS-Security provide the basic mechanisms on top of which secure messaging semantics can be defined for multiple message exchanges.
- WS-Secure Conversation defines extensions to allow security-context establishment and sharing, and session-key derivation.
- This allows contexts to be established, and potentially more efficient keys or new key material to be exchanged, thereby increasing the overall performance and security of the subsequent exchanges.

XKMS (XML Key Management Specification)

- Two parts:
  - XML key information service specification (XKISS) and XML key registration service specification (XKRSS).
- XKISS defines a protocol for resolving or validating public keys contained in signed and encrypted XML documents.
- XKRSS defines a protocol for public-key registration, revocation and recovery.
- The key aspect of XKMS is that it serves as a protocol specification between an XKMS client and an XKMS server, in which the XKMS server provides trust services to its clients (in the form of Web services) by performing various PKI operations, such as public-key validation, registration, recovery and revocation on their behalf.

WS Privacy and P3P

- Is a specification that describes the model for how a privacy language can be embedded into policies.
- WS-Security is used to associate privacy claims with a particular message.
- WS Privacy is currently being addressed under the P3P project.
- P3P currently addresses Web sites to extend their ability to express privacy preferences in a standard format that can be retrieved implicitly and implemented by user agents.
- P3P user agents will allow users to be informed of site practices (in both machine and human-readable formats) and to automate decision-making based on these practices when appropriate.

The P3P specification defines:

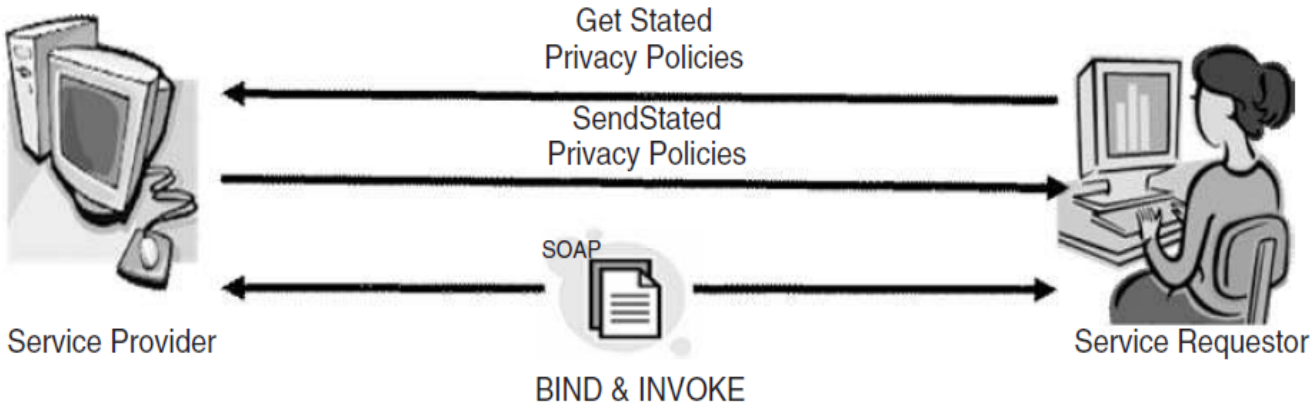
(1) A standard schema for data a Web site might wish to collect, known as the P3P base data schema.

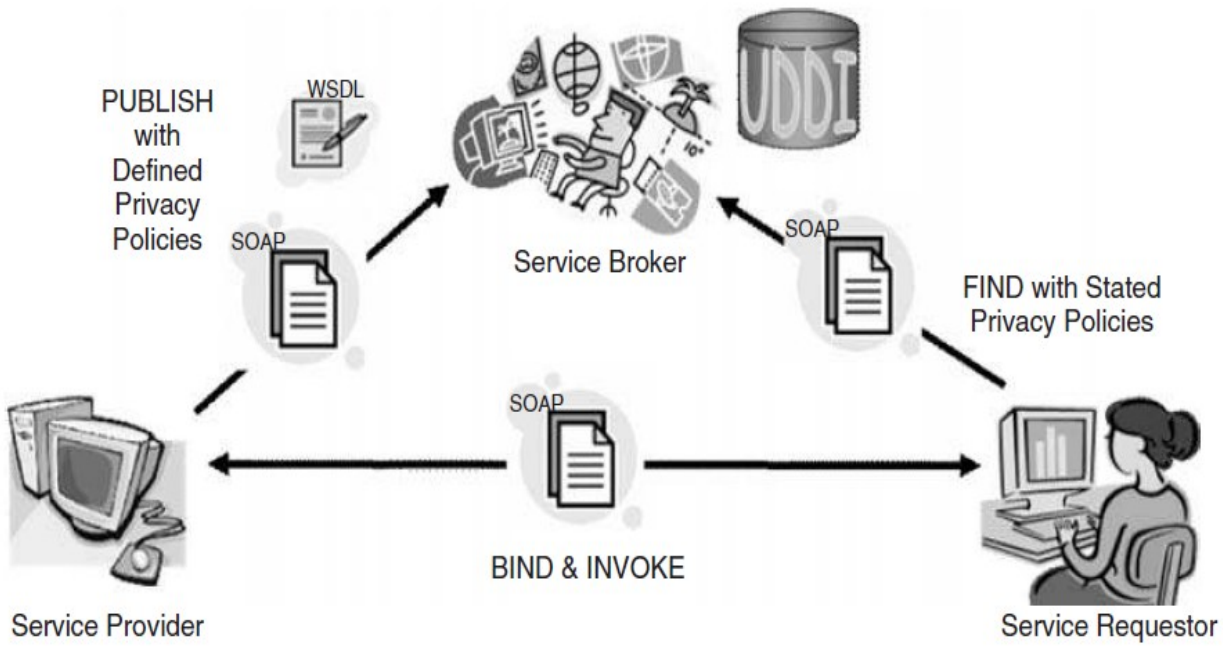
(2) A standard set of uses, recipients, data categories and other privacy disclosures.

(3) An XML format for expressing a privacy policy.

(4) A means of associating privacy policies with Web pages or sites, and cookies.

(5) A mechanism for transporting P3P policies over HTTP.



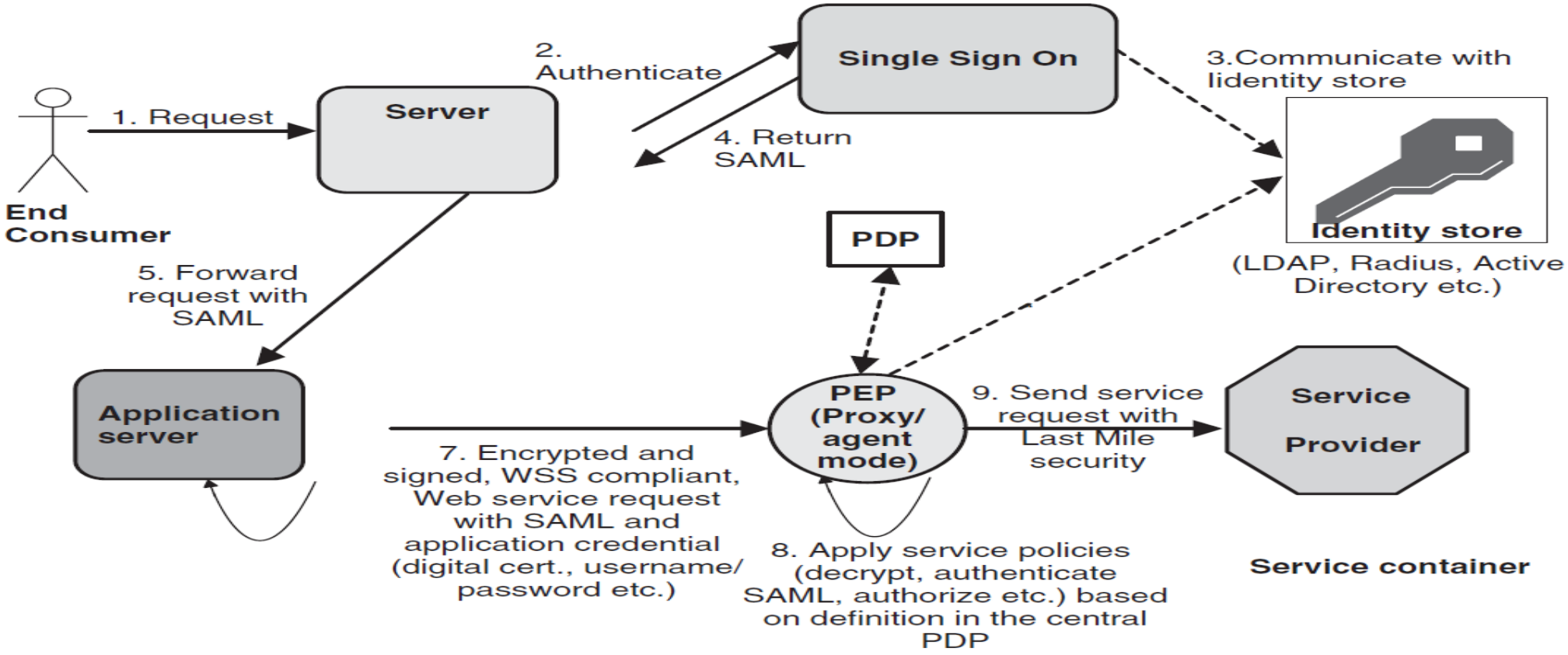


Element	Description
ENTITY	Gives a precise description of the legal entity making the representation of the privacy practices
ACCESS	Indicates whether the site provides access to various kinds of information
DISPUTES	Describes dispute resolution procedures that may be followed for disputes about the services' privacy practices, or in cases of protocol violation
REMEDIES	Specifies the possible remedies when a policy breach occurs
STATEMENT	May state that there is no data collected under this <STATEMENT>, or that all of the data referenced by that <STATEMENT>will be kept anonymous upon collection
CONSEQUENCE	Explains why the suggested practice may be valuable in a particular instance
PURPOSE	Must contain one or more purposes for data collection. Must explicitly state the possible purposes of data collection, such as telemarketing, administration and so on.
RECIPIENT	Indicates the legal entity beyond the stated service provider to whom the data could possibly be distributed, for example business partners and so on.
RETENTION	States the type of retention policy. This policy indicates whether the data will be retained for a specific time frame or indefinitely
CATEGORIES	Provide a small insight into the potential uses of data. Could indicate demographics, surveys and so on.

Deployment Architectures for SOA Security

Two Architectural Components
(1) Message-level security and policy infrastructure.
(2) XML firewall

Message-Level Security and Policy Infrastructure



Deployment Architectures for SOA Security

Message-level security and policy infrastructure

- This architecture decouples any policy or security constraints from the coding of the business logic of the system.
- Any changes in policy are handled at the PDP stores and PEPs.
- At the same time, the architecture is able to manage multiple existing mechanisms, be they existing LDAP/ID stores or existing authentication mechanisms.
- The key here is to note that SAML and WS-Security standards are being used interchangeably.
- While this represents the most generic of the security architectures for SOA, minor variations get induced depending upon the complexity of the underlying security requirements.

Deployment Architectures for SOA Security

XML Firewalls

- Operate at or above the application layer in the conventional TCP/IP stack.
- Traditional packet-filtering firewalls are incapable of handling denial-of-service (DOS) attacks at the XML and Web services layer.
- The XML and Web services-layer attacks are based on text fragments of XML, which cannot be diagnosed or detected by packet-filtering mechanisms.
- The XML firewalls, based on the idea of XML content inspection, are emerging.
- XML firewalls are available as software proxies or appliances.
- The software firewalls are generally high-performance proxies that provide additional defense to secure Web service deployments.
- These XML firewalls can be configured to perform authentication, authorization and auditing,and prevent the various Web-service attacks.
- Typically deployed behind the IP firewall, and control the message flow before it reaches the Web services.
- XML firewall appliances rank higher in terms of performance and scalability

Deployment Architectures for SOA Security

XML Firewalls

- XML firewalls inspect incoming and outgoing messages for vulnerabilities before the messages pass on to an application or client.
- They are designed to:
- address familiar Web-based attacks that can be transported via XML. Unlike a traditional firewall, an XML firewall works on a higher level and decides whether or not an XML message may access a specific operation of a specific Web service.
- The access is typically defined in terms of service-requester role and role-based access control (RBAC) rules. Correct authentication allows access to the specific operation and/or data item.
- Software XML firewalls are cheaper and have a lower total cost of ownership,but consequently provide less features. XML firewall appliances, on the other hand, can provide better performance and scalability.
- The general recommendation is always inclined toward the hardware-based XML firewall appliances due to the evolving nature of Web-service standards and the fact that the overall cost is not that prohibitive for an enterprise landscape

Deployment Architectures for SOA Security

XML Firewall Request Processing Design

XML firewall acts as a gatekeeper and security policies can be defined that determine the different actions taken during the processing of a request. The following is a general list of the steps taken during such processing:

(1).Parse the message headers for the following:

(a) check source IP address

(b) check requested resource (physical address/virtual address).

(2) Log the request or send the request to a real-time intrusion-detection system if that has been configured on the firewall.

(3) Check the underlying SSL certificate for its validity if the transport used is HTTPS.

(4) Classify the request based on URL, IP address and the SOAP headers.

(5) If a SOAP action header exists then associate the request with the action handler.

(6) Parse the SOAP envelope for credential checks.

(7) Apply the appropriate security-realm handler for the following credentials:

(a) username/password handler

(b) WS username token handler

(c) Kerberos token handler

(d) SAML token handler

(e) Any other custom SSO token-management handler.

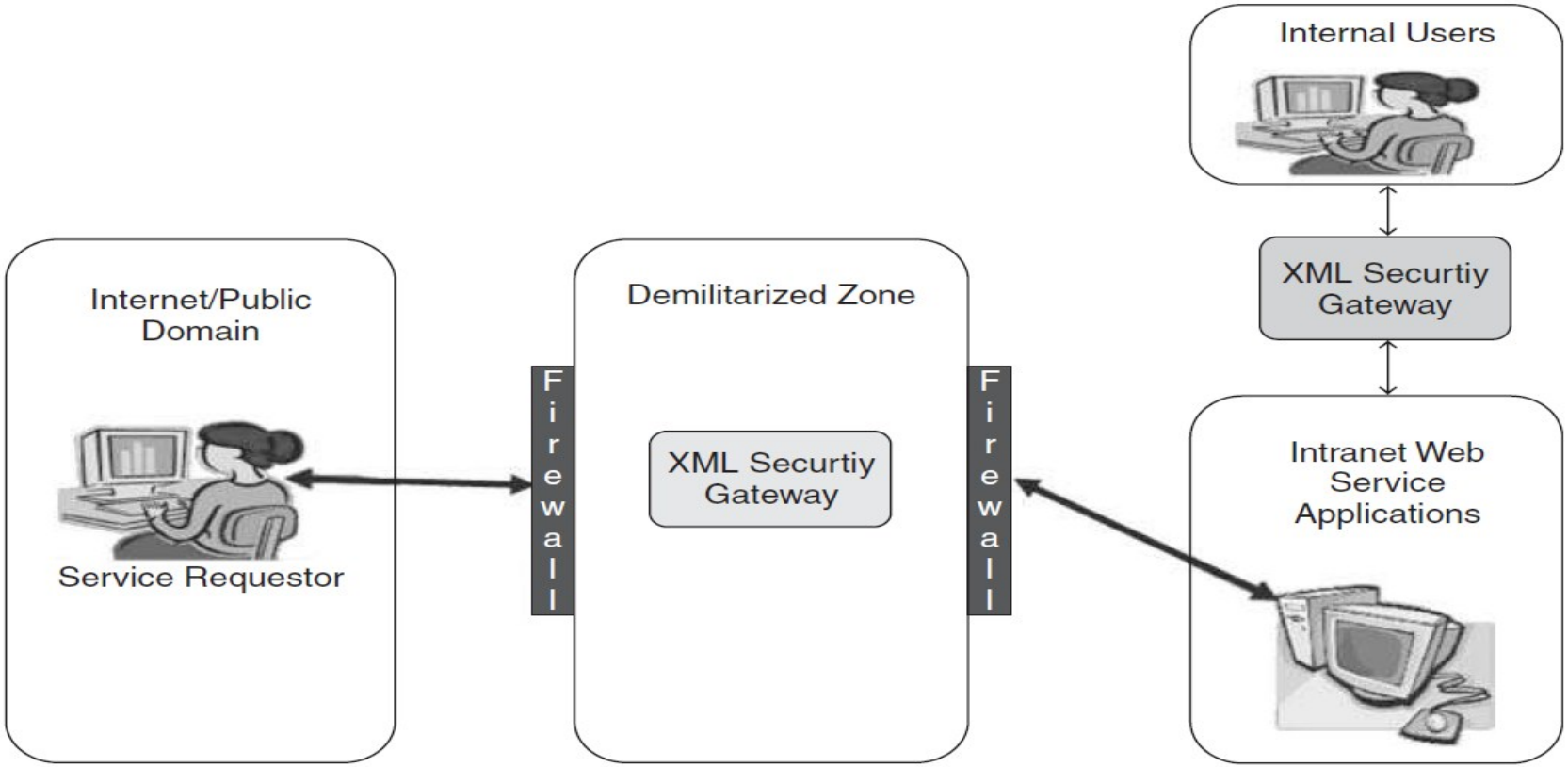
XML Firewall Request Processing Design

8) If the credential check is successful then associate a message handler with the message, depending on the message classification. There may be a chain of handlers that can be associated in a configured order.
(9) Check message for well-formedness and schema conformance.
(10) Evaluate the SOAP body of the message and make any additional credential checks that may be required.
(11) Message-level encryption could potentially exist, so possibly configure the firewall to check for the checksum validity to discover any message tampering.
(12) Decrypt the XML content and validate the XML Signature if associated with the message.
(13) Possibly configure the firewall to check for message complexity and size, to manage DOS attacks.
(14) Possibly apply XSLT validations to the message body to validate against the schema.
(15) Possibly apply constraint-based filters to the messages, to check the validity of the message values.
(16) Possibly apply pattern-matching filters to check for injection attacks.
(17) Check for any SOAP attachments associated with the message. Additional parameters can be configured to check for the attachment size and viruses,to prevent any hidden attacks.
(18) Process any additional SOAP headers if required.
(19) Determine the routing, depending upon whether the access requested is to:

(a) a single physical service
(b) a single virtual service
(c) multiple virtual services.

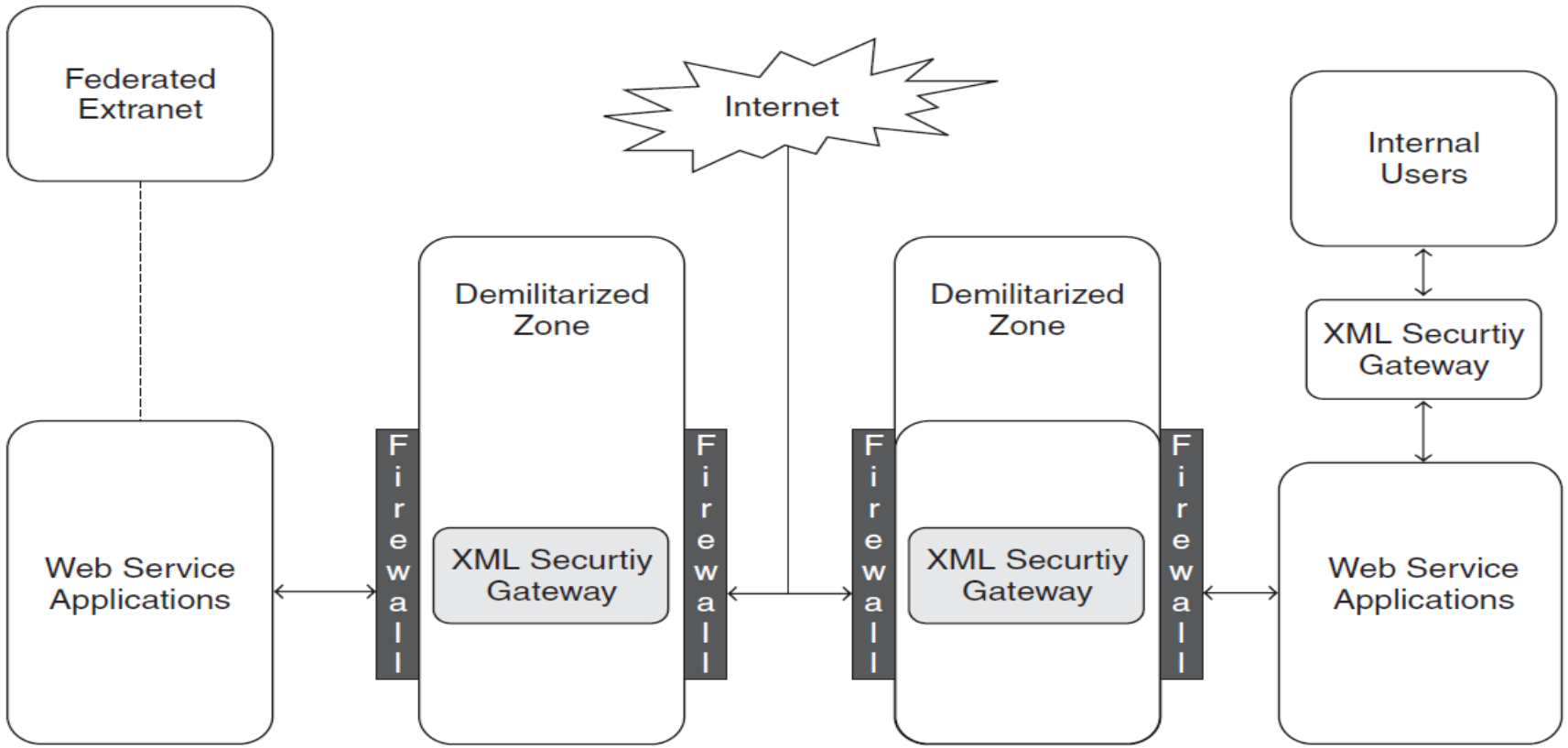
(20) Apply any postprocessing XSLT to the message.
(21) Recheck message validity, and generate a timestamp and audit the message.
(22) Route the message to the destination.

XML Firewall Deployment Architectures
Demilitarized zone scenario



- In a DMZ scenario two IP firewalls are used to create a demilitarized zone.
- The XML security gateway resides in this DMZ and sniffs and analyzes all incoming XML and SOAP traffic.
- The Web service end-point lies at the other end in a protected network.
- The whole design is based on a ‘defense of depth’ mechanism. The exterior IP firewall controls, restricts and enforces policies regarding access to the public network.
- The XML security gateway is used to perform authentication and authorization on the XML traffic.
- The interior firewall is responsible for monitoring traffic to the protected network. There is also an additional XML security gateway that monitors and controls XML traffic originating from the protected network or the internal users of an enterprise.

Federated trust (B2B) scenario



- The design is a double mirror image of the DMZ scenario,connected by the Internet.
- The underlying network connections could be secure private networks as per the security needs and the criticality of the information flow.
- XML gateways are installed on the service requester and the service provider.
- The XML gateway on the service requester provides access control and can enforce policies to control access to services and to the information in the requests.
- The gateways between the service provider and service requester need to be interoperable on user identity and their underlying roles, and probably even to provide SSO.
- The service gateways may use SAML as the common framework for authentication, authorization and even SSO token exchanges